NIST SP 800-30 Rev. 1

Guide to assessing risk

NIST SP 800-30 is a publication that provides guidance on performing risk assessments. It outlines strategies for identifying, analyzing, and remediating risks. Organizations use NIST SP 800-30 to gain insights into the potential likelihood and severity of risks—helping them make informed decisions about allocating resources, implementing controls, and prioritizing remediation efforts.

This four page document is adapted from NIST SP 800-30 Rev. 1. The term "Rev. 1" signifies that it is the first updated version of this publication. NIST occasionally revises its documents to incorporate new information, reflect changes in technology and regulatory requirements, or address feedback.

Note: NIST's Computer Security Resources Center contains more information on SP 800-30 Rev. 1.

Threat sources

NIST SP 800-30 defines and categorizes threat sources as entities or circumstances that can negatively impact an organization's information systems. This information is useful for identifying and assessing potential risks. When referencing it, consider the intent/capabilities of either internal and external threat sources.

Note: The following table lists a few possible *threat sources* that could compromise a publicly accessible database server.

Type	Examples	Description
Human	*Standard user* • Employee • Customer *Privileged user* • System administrator *Group* • Competitor • Supplier • Business partner • Nation state *Outsider* • Hacker • Hacktivist • Advanced persistent threat (APT)	Threats arising from individuals or groups who might purposefully or accidentally exploit cyber resources. For example, they might alter data in a way that negatively impacts the company. Alternatively, they might intentionally steal data and damage business equipment.

Technological	*Hardware* • Storage • Processing • Communications *Software* • Operating system(s) • Networking • Malicious software	Threats that originate from non-human factors. For example, failures of equipment due to aging, resource depletion, or other circumstances.
Environmental	*Operational environment* • Temperature controls • Humidity controls • Faulty power supplies *Natural hazards* • Power outages • Extreme weather events	Threats that arise from accidental, non-human factors. For example, equipment failures caused by the operational environment.

Threat events

NIST SP 800-30 defines and categorizes threat events as actual instances where a threat source exploits a vulnerability and causes damage or harm to an organization's information systems. This information is useful for gaining insights into the types of risks that assets face. More effective controls and countermeasures can be identified by understanding possible threat events,

Note: The following table lists just a few possible *threat events* that could compromise a publicly accessible database server.

Examples	**Description**
Perform reconnaissance and surveillance of organization	Threat source examines and assesses the company's vulnerabilities over time using various tools (e.g., scanning, physical observation).
Obtain sensitive information via exfiltration	Threat source installs malicious software on organizational systems to locate and acquire sensitive information.
Alter/Delete critical information	Threat source alters or deletes data that is critical to day-to-day business operations.

Craft counterfeit certificates.	Threat source compromises a certificate authority to make their connections appear legitimate.
Install persistent and targeted network sniffers on organizational information systems.	Threat source installs software designed to collect (sniff) network traffic over a continued period of time.
Conduct Denial of Service (DoS) attacks.	Threat source sends automated, excessive requests to overwhelm the system's operating capabilities.
Disrupt mission-critical operations.	Threat source compromises the integrity of information in such a way that prevents the business from carrying out critical operations.
Obfuscate future attacks.	Threat source takes actions to inhibit the effectiveness of the intrusion detection systems or auditing capabilities at the company.
Conduct "man-in-the-middle" attacks.	Threat source eavesdrops on sessions between internal and external systems. Later, they relay messages between organizational and external systems that make them believe they're talking directly to each other over a private connection.

Likelihood of a threat event

In general, the *likelihood* of a threat event should be a score based on a combination of factors. For example, any available evidence that you have, prior experience, and your expert judgment.

Consider the intent/capabilities of a threat source and potential threat events when producing a likelihood score.

Qualitative values	**Quantitative values**	**Description**
High	3	Threat source is almost certain to initiate a security event. An event could have multiple, severe, or catastrophic effects on business operations and assets.
Moderate	2	Threat source is somewhat likely to initiate a security event. An event could significantly reduce

		the functionality of organizational operations and assets.
Low	1	Threat source is highly unlikely to initiate a security event. An event could have minor, negligible effects on business operations and assets.

Severity of a threat event

In general, the *severity* of a threat event is a measure of its potential impact to business operations. For example, would the event cause a business function to stop entirely? Might it temporarily disrupt a business process and go unnoticed?

Consider the business impact of *threat events* when producing a severity score.

Qualitative values	**Quantitative values**	**Description**
High	3	Threat source is almost certain to initiate a security event. An event could have multiple, severe, or catastrophic effects on business operations and assets.
Moderate	2	Threat source is somewhat likely to initiate a security event. An event could significantly reduce the functionality of organizational operations and assets.
Low	1	Threat source is highly unlikely to initiate a security event. An event could have minor, negligible effects on business operations and assets.